

Network & IAM standards (NSG, UAMI, PIM)

Network & IAM standards (banking baseline)

SOW items 2 and 4 — RHEL workload network standards + environment improvement recommendations. Client implements firewall/NSG/RBAC. Industry authorities: .

Azure terminology

AWS habit	Azure (this engagement)
Security group	NSG on subnet/NIC
IAM role	UAMI + Azure RBAC
IAM user	Entra ID user + group RBAC
Secrets Manager	Key Vault

Prescriptive NSG model

Module: `infra/terraform/modules/nsg-baseline/`

VM	Inbound	Outbound
Runner	SSH from Bastion CIDR only	VNet, AzureCloud:443, Internet:443 (GitHub), Storage
Runtime	SSH from Bastion; app ports from APIM CIDR	VNet, AzureCloud, Storage, Entra — plus client allow-list

Default: Deny all inbound (priority 4096).

Prescriptive IAM model

Principal	Scope	Roles
uami-{env}-github-runner	ACR, Key Vault	AcrPush, Key Vault Secrets User
uami-{env}-podman-runtime	ACR, Key Vault, Storage (if NFS)	AcrPull, Key Vault Secrets User, Storage File Data Privileged Contributor
Humans	Subscription/RG	No Owner on workload RGs; Entra SSH for break-fix
Consultant	Subscription	Reader only (assessment) — time-bound via PIM (see below)
Vendor / guest engineers	Subscription or RG	Eligible roles only; no permanent assignment

Never: Contributor on workload UAMIs; storage account keys on VM; shared admin accounts; long-lived Reader for consultants.

Developer temporary CLI access (Track 2 — banking default)

Developers (Anatoliy's team) need `az` on **dev subscription only** — not UAMI, not shared admin, not permanent Contributor.

Step	Standard
Group	grp-platform-developers (Entra) — individual members only
Roles	PIM eligible: Reader (dev sub/RG), AcrPush (dev ACR), Key Vault Secrets User (dev KV)
Activate	Entra PIM → My roles — MFA, justification, ≤8h
CLI login	<code>./scripts/az-developer-login.sh</code> or <code>/opt/compliance/bootstrap/az-login-developer.sh</code> on dev VM
VMs (UAT/prod)	UAMI only — <code>az login --identity</code> ; developers do not use Entra login on runner/runtime

IaC: `infra/terraform/modules/developer-cli-access/`

Doc:

Temporary Entra access — consultant discovery (Track B)

Consultants and network engineers need portal read for discovery. Same PIM pattern, **Reader only**, no `AcrPush` unless explicitly chartered.

Prescriptive pattern

Principle	Standard
Identity type	Individual Entra ID user per person — consultant as guest (<code>user@consultant.com</code>) or workforce account
Role model	Privileged Identity Management (PIM) — eligible assignment, activate only when needed
Consultant Azure scope	<code>Reader</code> at subscription (dev + prod subs) — never <code>Contributor</code> , <code>User Access Administrator</code> , or Key Vault secret read
Activation	MFA required; max duration 8 hours (or client policy cap); optional approval (Patrick / platform)
Linux / Bastion	Same user identity — Entra ID SSH or Bastion with per-user account; no shared <code>deploy</code> password in email
Audit	PIM activation logs + Entra sign-in logs retained per GRC policy
Offboarding	Access review at engagement end — remove eligible assignments and guest accounts within 5 business days

What not to do

Anti-pattern	Why
Service principal + client secret for consultant portal access	No human attribution; secret sprawl
Permanent <code>Reader</code> for 12-week engagement	Violates least-privilege / access-review norms
Shared break-glass account for discovery	No individual accountability
Contributor “to speed up assessment”	Out of scope; client implements changes

Fallback (no PIM license)

If PIM is unavailable, use **time-bound** direct role assignment with documented **end date** (engagement end + 5 days) and quarterly access review. Still require individual Entra users and MFA — not a substitute for PIM long term.

Track B deliverables enabled

Temporary Entra access unblocks: NSG rule inventory, VNet/peering validation, private endpoint DNS checks, and completion of without client exporting screenshots only.

Azure Policy (reference samples)

Policy	File
SIG-only Linux images	policies/deny-non-sig-linux-images.json
Trusted Launch required	policies/require-trusted-launch-linux.json
No public IP on NICs	policies/deny-public-ip-on-bank-vms.json

Client GRC assigns initiative to workload subscriptions.

Consultant vs client

Activity	Vaco	Client
NSG/firewall rules draft	Yes	Implements
UAMI + RBAC Terraform	Reference	Applies
Entra SSH / PIM / temp guest access	Advise (Track B pattern above)	Implements
Policy initiative	Sample JSON	Assigns

Industry references

Full map:

Topic	Primary sources
NSG model	Azure NSG MCSB network security
UAMI / RBAC	Managed identities Azure RBAC best practices
PIM / JIT access	Privileged Identity Management NIST SP 800-207
Entra SSH	Linux VM Entra sign-in
Azure Policy	Azure Policy CIS Azure Foundations
Banking context	FFIEC IS Handbook — Access Control

Document history

Version	Date
0.1	2026-05-28
0.2	2026-05-28
0.3	2026-05-28